

Data Security Policy Handbook

Acme Corporation - Information Security Program

1. Purpose and Scope

This handbook establishes the mandatory data security controls that apply to all Acme Corporation employees, contractors, and third-party vendors who access, process, store, or transmit company information on any device or network connected to Acme systems. It covers access control, data classification, encryption, backup and retention, incident response, and vendor risk management. Compliance with this handbook is a condition of employment and of any vendor services agreement, and violations are subject to disciplinary action up to and including termination of employment or contract.

2. Data Classification

All company information must be classified into one of four tiers: Public, Internal, Confidential, or Restricted. Public data may be shared outside the company without restriction. Internal data is intended for employees only and should not be shared externally without approval. Confidential data includes customer records, financial statements, and unreleased product plans, and requires manager approval before external sharing. Restricted data includes authentication credentials, encryption keys, and personally identifiable information subject to regulatory protection, and may only be accessed by employees with an explicit, documented business need and only over an encrypted channel.

3. Access Control

Access to company systems is granted on a least-privilege basis: employees receive only the permissions required for their current role, and access is reviewed quarterly by system owners. All accounts must use multi-factor authentication for any system holding Confidential or Restricted data. Shared accounts are prohibited except for designated service accounts that are inventoried and rotated on a documented schedule. When an employee changes roles or leaves the company, their access must be revoked or adjusted within one business day by the IT Service Desk, and this deprovisioning is logged for the annual access audit.

3.1 Password and Lockout Policy

Passwords must be at least twelve characters and are not required to be rotated on a fixed schedule, consistent with current guidance that favors length over forced rotation. Accounts are automatically locked after five consecutive failed login attempts within a fifteen-minute window, and the lockout is released automatically after thirty minutes or sooner by an IT Service Desk agent after identity verification.

4. Backup and Data Retention

4.1 Backup Architecture

Acme operates a tiered backup architecture spanning production databases, file servers, and virtual machine images across two geographically separate data centers. Primary backups are taken as nightly incremental snapshots orchestrated by the central backup scheduler, capturing only the blocks that changed since the previous snapshot to minimize storage growth and network load on the production storage array. In addition to the nightly incrementals, a full baseline backup of every production volume is taken once per week during the Saturday maintenance window, when application traffic is lowest and the backup job can saturate the available network bandwidth without degrading customer-facing performance.

Every backup, whether incremental or full, is encrypted at rest using AES-256 before it ever leaves the primary data center, and the encryption keys used for backup archives are managed separately from the keys used for live production data, stored in a dedicated hardware security module that only the backup service account and two named security engineers can access. Backups are then replicated asynchronously to an off-site cold storage facility operated by a certified third-party provider under a signed data processing agreement, and the replication job verifies a checksum of every archive after transfer to guard against silent corruption in transit. Backup integrity is additionally verified on a monthly basis through a full restoration drill performed by the infrastructure team, in which a randomly selected production volume is restored into an isolated recovery environment and validated against a checksum manifest, with results logged in the disaster-recovery runbook for audit purposes. Any restoration drill that fails validation triggers an immediate incident ticket and a follow-up backup within twenty-four hours.

The backup scheduler itself runs on a dedicated, hardened host that is patched on the same monthly cycle as the rest of the production fleet, and access to the scheduler's administrative console is restricted to the infrastructure team through a bastion host with session recording enabled, so that every configuration change to the backup jobs is attributable to a named engineer and reviewable after the fact. Backup job definitions, including source volume, schedule, retention target, and destination storage tier, are stored as version-controlled configuration rather than edited directly in the scheduler's user interface, so that any change to how a given system is backed up goes through the same peer-review process as a production code change, and can be rolled back if a misconfiguration is discovered.

Capacity on the cold storage tier is monitored continuously, and the infrastructure team receives an automated alert when utilization crosses eighty percent of the provisioned quota, well before the tier is at risk of rejecting new archives, giving enough lead time to either expand the quota or investigate unexpectedly rapid growth in backup volume, which is itself sometimes an early indicator of a runaway job or an unexpected spike in production data.

After all of this scheduling, encryption, replication, and verification activity, the retention period for full system backups held in cold storage is 90 days, after which backup archives are automatically purged by the cold storage provider's lifecycle policy and cannot be recovered.

5. Encryption in Transit and at Rest

All Confidential and Restricted data must be encrypted using TLS 1.2 or higher whenever it is transmitted across any network, including internal network segments, and encrypted at rest using AES-256 on any storage volume, database, or removable media. Laptops issued to employees are encrypted at the disk level by default through the corporate device management platform, and encryption cannot be disabled by the end user. Any exception to this policy, for example for a legacy system that cannot support current TLS versions, must be documented, time-boxed, and approved in writing by the Chief Information Security Officer before the exception takes effect.

5.1 Vendor and Third-Party Risk

Any vendor that will store, process, or transmit Confidential or Restricted data on Acme's behalf must complete a security questionnaire and pass a risk review before a contract is signed, and high-risk vendors are reassessed annually. Vendor contracts must include a data processing addendum specifying encryption, breach-notification, and data-deletion obligations consistent with this handbook.

6. Security Incident Response

6.1 Reporting

All security incidents, including suspected phishing, malware infections, lost or stolen devices, and unauthorized access, must be reported to the Security Operations Center within 1 hour of detection. Reports may be submitted through the internal incident portal or by calling the 24/7 security hotline. Delayed reporting is itself treated as a policy violation, since containment effectiveness drops sharply once several hours have passed.

6.2 Response and Containment

Upon receiving a report, the on-call security engineer triages the incident within fifteen minutes and assigns a severity level. Severity 1 incidents (active data exfiltration or ransomware) trigger immediate network isolation of affected systems and a page to the full incident response team.

7. Employee Security Training

All employees complete mandatory security awareness training within their first week of employment and an annual refresher thereafter. Training covers phishing recognition, password hygiene, data classification, and the incident reporting process described in Section 6. Completion is tracked in the learning management system, and managers receive an escalation notice for any direct report who has not completed the annual refresher within thirty days of its due date.

8. Policy Review

This handbook is reviewed annually by the Information Security team and approved by the Chief Information Security Officer. Material changes are communicated to all employees by email and take effect thirty days after publication unless an earlier effective date is required by law or by an active security incident.